	แผนการจัดการเรียนรู้	หน่วยที่ 4
	รหัสวิชา 31910-2007 ชื่อวิชา เครือข่ายคอมพิวเตอร์และความปลอดภัยสำหรับธุรกิจดิจิทัล	สอนครั้งที่ 17
	ชื่อหน่วยการเรียนรู้ ความปลอดภัยทางไซเบอร์และกฎหมาย PDPA	ทฤษฎี 2 ชม. ปฏิบัติ 2 ชม.
ชื่อเรื่อง/งาน การป้องกันการโจมตีทางไซเบอร์เบื้องต้น (Cyber Attack Prevention)		

1. ผลลัพธ์การเรียนรู้ระดับหน่วยการเรียน

1.1 ผู้เรียนสามารถระบุและอธิบายรูปแบบการโจมตีทางไซเบอร์ที่พบบ่อยในสภาพแวดล้อมธุรกิจดิจิทัลได้

1.2 ผู้เรียนสามารถตรวจสอบและตั้งค่าความปลอดภัยเบื้องต้นบนระบบปฏิบัติการคอมพิวเตอร์และบัญชีออนไลน์ได้

1.3 ผู้เรียนมีความตระหนักรู้ถึงภัยคุกคามทางไซเบอร์และระมัดระวังในการทำธุรกรรมหรือส่งข้อมูลบนเครือข่าย

2. อ้างอิงมาตรฐาน/เชื่อมโยงกลุ่มอาชีพ

2.1 มาตรฐานอาชีพ - สมรรถนะย่อย -

1) เกณฑ์การปฏิบัติงาน -

2) วิธีประเมิน -

3) หลักฐานการปฏิบัติงาน (Performance Evidence)

4) หลักฐานความรู้ (Knowledge Evidence)

2.2 บูรณาการกลุ่มอาชีพ.....

3. สมรรถนะประจำหน่วย

3.1 ประมวลความรู้เกี่ยวกับรูปแบบภัยคุกคามทางไซเบอร์และหลักการรักษาความปลอดภัยของข้อมูล

3.2 ประยุกต์ใช้เครื่องมือรักษาความปลอดภัยเบื้องต้นเพื่อป้องกันการโจมตีทางเครือข่ายและระบบคอมพิวเตอร์

4. จุดประสงค์เชิงพฤติกรรม

4.1 ผู้เรียนสามารถแยกแยะความแตกต่างระหว่าง Malware, Ransomware และ Phishing จากกรณีศึกษาได้ถูกต้อง

4.2 ผู้เรียนสามารถวิเคราะห์และจับผิดอีเมลหรือข้อความหลอกลวง (Social Engineering) ที่มุ่งเป้าโจมตีธุรกิจได้

4.3 ผู้เรียนสามารถเปิดใช้งานและตรวจสอบสถานะของ Windows Defender Firewall และ Antivirus บนเครื่องคอมพิวเตอร์ได้

4.4 ผู้เรียนสามารถตั้งค่ารหัสผ่านที่รัดกุม (Strong Password) และเปิดใช้งานการยืนยันตัวตนแบบสองขั้นตอน (2FA) ได้

4.5 ผู้เรียนเห็นความสำคัญของการอัปเดตระบบและไม่คลิกลิงก์ที่น่าสงสัย

5. สาระการเรียนรู้

5.1 ภาพรวมของภัยคุกคามทางไซเบอร์ (Cyber Threats): ทำไมธุรกิจดิจิทัลถึงเป็นเป้าหมายหลักของแฮกเกอร์

5.2 รูปแบบการโจมตีที่พบบ่อย (Common Cyber Attacks):

Malware & Ransomware: มัลแวร์และมัลแวร์เรียกค่าไถ่ (กรณีศึกษา: การล็อกไฟล์บัญชีของบริษัท)

Phishing & Social Engineering: การหลอกลวงด้วยวิศวกรรมสังคม (เช่น อีเมลปลอมแปลงเป็นธนาคาร หรือใบแจ้งหนี้ปลอม)

Man-in-the-Middle (MitM): การดักจับข้อมูลเมื่อใช้ Wi-Fi สาธารณะ

DDoS (Distributed Denial of Service): การโจมตีเว็บไซต์ให้ล่ม

5.3 แนวทางการป้องกันตัวเบื้องต้น (Basic Cyber Defense):

การสร้างรหัสผ่านที่รัดกุม (Password Security) และการใช้ Password Manager

การเปิดใช้งาน Two-Factor Authentication (2FA) / Multi-Factor Authentication (MFA)

การตั้งค่าและตรวจสอบ Windows Security (Firewall & Antivirus)

การแยกแยะลิงก์จริงและลิงก์ปลอม (URL Checking)

6. กิจกรรมการเรียนรู้

1. ขั้นนำเข้าสู่บทเรียน

ครูเปิดคลิปข่าวหรือยกตัวอย่างข่าวจริง เช่น "บริษัทถูกแฮกเกอร์ปล่อย Ransomware ล็อกข้อมูลลูกค้าทั้งหมดและเรียกค่าไถ่ 10 ล้านบาท" หรือ "พนักงานบัญชีหลงเชื่ออีเมลปลอม โอนเงินให้มิจฉาชีพ"

ครูตั้งคำถาม: "ถ้าเรื่องนี้เกิดขึ้นกับบริษัทที่เราเป็นเจ้าของ หรือเราเป็นคนคลิกลิงก์นั้นเอง จะเกิดความเสียหายอะไรบ้าง?" (กระตุ้นให้เห็นว่าภัยไซเบอร์ไม่ใช่เรื่องไกลตัว และสร้างความเสียหายทางธุรกิจมหาศาล)

2. ขั้นสอนและอธิบายเนื้อหา

ครูอธิบายรูปแบบภัยคุกคามแต่ละประเภท โดยใช้การเปรียบเทียบให้เข้าใจง่าย (เช่น Firewall คือ รปภ. หน้าตึก, Antivirus คือ ตำรวจที่เดินตรวจตราในตึก, Phishing คือ โจรที่ปลอมตัวเป็นพนักงานส่งพัสดุมาหลอกขอรับกุญแจ)

ครูสาธิตวิธีการจับผิดอีเมล Phishing (ดูชื่อผู้ส่ง, การสะกดคำผิด, ลิงก์ที่ซ่อนอยู่เมื่อเอาเมาส์ไปชี้)

ครูสาธิตการเข้าไปตรวจสอบสถานะความปลอดภัยในระบบ Windows (Windows Defender, Firewall)

3. ขั้นฝึกปฏิบัติ

ภารกิจที่ 1: Phishing Hunter (นักล่าลิงก์ปลอม): ครูแจกใบงานที่มีตัวอย่างภาพหน้าจออีเมลและ SMS จำนวน 5 รูป (ผสมทั้งของจริงและของหลอกลวง เช่น ใบแจ้งหนี้ปลอม, แจ้งเตือนพัสดุตกค้าง) ให้นักศึกษาทำงานคู่เพื่อวิเคราะห์ว่าภาพไหนเป็น Phishing พร้อมวงกลมจุดที่น่าสงสัย

ภารกิจที่ 2: Security Audit (ตรวจสอบความปลอดภัยเครื่อง): ให้นักศึกษาตรวจสอบคอมพิวเตอร์ของตนเองหรือเครื่องในห้องปฏิบัติการ ว่า Firewall เปิดทำงานอยู่หรือไม่ และให้ทดลองเข้าไปตั้งค่าเปิดใช้งาน 2FA (Two-Factor Authentication) ในบัญชี Google หรือ Facebook ของตนเองผ่านสมาร์ทโฟน

4. ขั้นสรุปและประเมินผล

ครูสุ่มตัวแทนกลุ่มให้ออกมาเฉลยใบงาน Phishing Hunter พร้อมอธิบายเหตุผลว่าทำไมถึงคิดว่าเป็นอีเมลหลอกลวง

ครูสรุปย้ำกฎทองคำของความปลอดภัยไซเบอร์: "อย่าไว้ใจลิงก์แปลกหน้า, ตั้งรหัสผ่านให้เดายาก, และอัปเดตระบบเสมอ"

5. ขั้นขยายผลการเรียนรู้

ครูให้นักศึกษาลองเข้าเว็บไซต์ haveibeenpwned.com เพื่อตรวจสอบว่าอีเมลที่ตนเองใช้อยู่เคยมีประวัติรหัสผ่านรั่วไหลจากเว็บไซต์อื่นหรือไม่ (กิจกรรมนี้มักสร้างความตื่นตัวได้ดีมาก) และเชื่อมโยงไปสู่เรื่องการรักษาข้อมูลส่วนบุคคล (PDPA) ในสัปดาห์ถัดไป

7. สื่อและแหล่งการเรียนรู้

7.1 ข่าวหรือคลิปวิดีโอเหตุการณ์การโจมตีทางไซเบอร์ในภาคธุรกิจ

7.2 สไลด์นำเสนอเรื่อง Cybersecurity Basics

7.3 ใบงานกิจกรรม "Phishing Hunter" (รูปภาพกรณีศึกษาอีเมลและ SMS)

7.4 คอมพิวเตอร์และสมาร์ทโฟนที่มีการเชื่อมต่ออินเทอร์เน็ต

8. หลักฐานการเรียนรู้

สิ่งที่วัด (KPA)	วิธีวัด	เครื่องมือ	เกณฑ์การผ่าน (Rubrics)
K: ความเข้าใจภัยคุกคามทางไซเบอร์	ตรวจใบงาน Phishing Hunter	แบบฝึกหัด/ใบงาน	ระบุอีเมล/ข้อความหลอกลวงและบอกจุดสังเกตได้ถูกต้องเกิน 80%
P: ทักษะการป้องกันและตั้งค่าความปลอดภัย	ตรวจสอบหน้าจอการตั้งค่า 2FA และสถานะ Firewall	แบบประเมินภาคปฏิบัติ	เปิดใช้งาน 2FA สำเร็จ และสามารถตรวจสอบหน้าต่าง Windows Security ได้ด้วยตนเอง
A: ความตระหนักรู้และระมัดระวัง	สังเกตพฤติกรรมระหว่างการวิเคราะห์กรณีศึกษา	แบบสังเกตพฤติกรรม	มีส่วนร่วมในการวิเคราะห์ ไม่คลิกลิงก์มั่วซั่ว และตระหนักถึงผลกระทบต่อองค์กร

9. การวัดและประเมินผล

9.1 เกณฑ์การปฏิบัติงาน

สามารถวิเคราะห์และแยกแยะภัยคุกคามแบบ Social Engineering ได้ พร้อมทั้งตั้งค่าความปลอดภัยพื้นฐาน (2FA, Firewall) ให้กับบัญชีและอุปกรณ์ของตนเองได้

9.2 วิธีการประเมิน

ตรวจใบงานการวิเคราะห์กรณีศึกษา และตรวจสอบผลการปฏิบัติงานหน้าจอคอมพิวเตอร์/สมาร์ทโฟน

9.3 เครื่องมือประเมิน

ใบงาน Phishing Hunter และแบบประเมินผลการปฏิบัติงาน

10. บันทึกผลหลังการจัดการเรียนรู้

10.1 ผลการจัดการเรียนรู้ที่เกิดขึ้นกับผู้เรียน

.....

.....

10.2 ปัญหา อุปสรรคที่พบ

.....

.....

10.3 การแก้ไขปัญหา

1) ผลการแก้ไขปัญหาทีส่งผลลัพธ์ที่ดีต่อผู้เรียน

.....

.....

2) แนวทางแก้ปัญหาในครั้งต่อไป

.....

.....

	ใบความรู้ ที่ 7	หน่วยที่ 4
	รหัสวิชา 31910-2007 ชื่อวิชา เครือข่ายคอมพิวเตอร์และความปลอดภัย	สอนครั้งที่ 13 - 16
	ชื่อหน่วยการเรียนรู้ ความปลอดภัยทางไซเบอร์และกฎหมาย PDPA	ทฤษฎี 2 ชม. ปฏิบัติ 2 ชม.
ชื่อเรื่อง/งาน การป้องกันการโจมตีทางไซเบอร์เบื้องต้น (Cyber Attack Prevention)		

1. ผลลัพธ์การเรียนรู้ระดับหน่วยการเรียน

1.1 ผู้เรียนสามารถระบุและอธิบายรูปแบบการโจมตีทางไซเบอร์ที่พบบ่อยในสภาพแวดล้อมธุรกิจดิจิทัลได้

1.2 ผู้เรียนสามารถตรวจสอบและตั้งค่าความปลอดภัยเบื้องต้นบนระบบปฏิบัติการคอมพิวเตอร์และบัญชีออนไลน์ได้

1.3 ผู้เรียนมีความตระหนักรู้ถึงภัยคุกคามทางไซเบอร์และระมัดระวังในการทำธุรกรรมหรือส่งข้อมูลบนเครือข่าย

2. อ้างอิงมาตรฐาน/เชื่อมโยงกลุ่มอาชีพ

2.1 มาตรฐานอาชีพ - สมรรถนะย่อย -

1) เกณฑ์การปฏิบัติงาน -

2) วิธีประเมิน -

3) หลักฐานการปฏิบัติงาน (Performance Evidence)

4) หลักฐานความรู้ (Knowledge Evidence)

2.2 บูรณาการกลุ่มอาชีพ.....

3. สมรรถนะประจำหน่วย

3.1 ประมวลความรู้เกี่ยวกับรูปแบบภัยคุกคามทางไซเบอร์และหลักการรักษาความปลอดภัยของข้อมูล

3.2 ประยุกต์ใช้เครื่องมือรักษาความปลอดภัยเบื้องต้นเพื่อป้องกันการโจมตีทางเครือข่ายและระบบคอมพิวเตอร์

4. จุดประสงค์เชิงพฤติกรรม

4.1 ผู้เรียนสามารถแยกแยะความแตกต่างระหว่าง Malware, Ransomware และ Phishing จากกรณีศึกษาได้ถูกต้อง

4.2 ผู้เรียนสามารถวิเคราะห์และจับผิดอีเมลหรือข้อความหลอกลวง (Social Engineering) ที่มุ่งเป้าโจมตีธุรกิจได้

4.3 ผู้เรียนสามารถเปิดใช้งานและตรวจสอบสถานะของ Windows Defender Firewall และ Antivirus บนเครื่องคอมพิวเตอร์ได้

4.4 ผู้เรียนสามารถตั้งค่ารหัสผ่านที่รัดกุม (Strong Password) และเปิดใช้งานการยืนยันตัวตนแบบสองขั้นตอน (2FA) ได้

4.5 ผู้เรียนเห็นความสำคัญของการอัปเดตระบบและไม่คลิกลิงก์ที่น่าสงสัย

5. เนื้อหาสาระ

ความสำคัญของความปลอดภัยทางไซเบอร์ (Cybersecurity) ในยุคที่ทุกธุรกิจขับเคลื่อนด้วยข้อมูล (Data-driven) ข้อมูลลูกค้า บัญชีการเงิน หรือแผนธุรกิจล้วนถูกเก็บอยู่ในระบบคอมพิวเตอร์ แฮกเกอร์จึงมุ่งเป้ามาที่องค์กรธุรกิจเพื่อขโมยข้อมูลเหล่านั้นไปขายหรือเรียกค่าไถ่ การมีความรู้ด้านความปลอดภัยทางไซเบอร์จึงเปรียบเสมือนการสร้าง "กำแพงและยามรักษาความปลอดภัย" ให้กับบริษัท

รูปแบบภัยคุกคามทางไซเบอร์ที่พบบ่อย (Common Cyber Threats)

1. Malware (มัลแวร์): ซอฟต์แวร์ประสงค์ร้ายทุกชนิดที่แอบแฝงเข้ามาทำลายหรือขโมยข้อมูลในเครื่องคอมพิวเตอร์ (เช่น ไวรัส, โทรจัน, หนอนคอมพิวเตอร์)
2. Ransomware (มัลแวร์เรียกค่าไถ่): เป็นมัลแวร์ที่อันตรายที่สุดสำหรับธุรกิจ เมื่อติดแล้วมันจะทำการ "ล็อกไฟล์ (Encrypt)" ทั้งหมดในเครื่องและในวง LAN ทำให้เปิดไฟล์งานไม่ได้ แฮกเกอร์จะส่งข้อความมาเรียกค่าไถ่ (มักให้จ่ายเป็น Bitcoin) เพื่อแลกกับรหัสปลดล็อก
3. Phishing (ฟิชชิง): การหลอกลวงแบบตกปลา โดยแฮกเกอร์จะส่งอีเมลหรือ SMS ปลอมตัวเป็นธนาคาร, บริษัทขนส่ง หรือหน่วยงานรัฐ เพื่อหลอกให้เหยื่อตกใจและกดลิงก์เข้าไปกรอกรหัสผ่าน หรือดาวน์โหลดไฟล์ไวรัส
4. Social Engineering (วิศวกรรมสังคม): การแฮก "จิตวิทยาของมนุษย์" แทนการแฮกระบบคอมพิวเตอร์ เช่น การโทรมาหลอกว่าเป็นเจ้าหน้าที่ IT ของบริษัทเพื่อขอรหัสผ่านพนักงาน
5. Man-in-the-Middle (MitM): การดักจับข้อมูลกลางทาง มักเกิดขึ้นเมื่อพนักงานนำโน้ตบุ๊กไปต่อ Wi-Fi สาธารณะฟรีที่ไม่มีรหัสผ่าน แฮกเกอร์ที่อยู่ในวง Wi-Fi เดียวกันจะสามารถดักอ่านข้อมูลที่พนักงานส่งออกไปได้

แนวทางการป้องกันสำหรับผู้ปฏิบัติงานในธุรกิจดิจิทัล

1. การตั้งรหัสผ่านที่รัดกุม (Strong Password): ควรยาวอย่างน้อย 12 ตัวอักษร ผสมตัวพิมพ์เล็ก พิมพ์ใหญ่ ตัวเลข และอักขระพิเศษ ห้ามใช้รหัสผ่านเดียวกันในทุกเว็บไซต์ (อาจใช้โปรแกรม Password Manager ช่วยจำ)
2. เปิดใช้งาน Two-Factor Authentication (2FA) / Multi-Factor Authentication (MFA): การยืนยันตัวตนแบบสองขั้นตอน เช่น กรอกรหัสผ่านเสร็จ ต้องกรอกรหัส OTP ที่ส่งเข้ามือถืออีกครั้ง เป็นวิธีที่ป้องกันการถูกแฮกบัญชีได้ผลดีที่สุดในปัจจุบัน
3. ตรวจสอบลิงก์ (URL Checking): ก่อนคลิกลิงก์ใดๆ ในอีเมล ให้เอาเมาส์ไปชี้ค้างไว้ (Hover) เพื่อดูว่าที่อยู่เว็บปลายทาง (URL) สะกดถูกต้องหรือไม่ (เช่น หน้าตาเหมือนเว็บธนาคาร แต่ URL เป็น kaslkornbank.com เป็นต้น)
4. อัปเดตระบบปฏิบัติการและเปิดใช้งาน Firewall: หมั่นกด Update Windows และเปิดใช้งาน Windows Defender Firewall เพื่ออุดช่องโหว่และป้องกันผู้บุกรุกจากภายนอกเครือข่าย

6. แบบฝึกหัด/แบบทดสอบ

กิจกรรม Workshop "Cyber Security Audit & Phishing Hunter" โจทย์สถานการณ์: คุณได้รับมอบหมายให้เป็นเจ้าหน้าที่ตรวจสอบความปลอดภัยของออฟฟิศ คำสั่งปฏิบัติการ:

1. ภารกิจ Phishing Hunter (นักล่าลิงก์ปลอม): ครูจะแจกภาพตัวอย่างหน้าจออีเมลและ SMS จำนวน 5 ภาพ ให้นักศึกษาทำงานคู่ วิเคราะห์ว่าภาพใดคือ "ของจริง" และภาพใดคือ "Phishing" พร้อมใช้ปากกาวงกลมจุดที่ผิดสังเกต (เช่น ที่อยู่อีเมลผู้ส่งผิดปกติ, ลิงก์ที่ซ่อนอยู่ไม่ตรงกับชื่อเว็บ, การใช้ภาษาที่เร่งรัดให้ตื่นตระหนก)
2. ภารกิจ Security Audit (ตรวจสอบความปลอดภัยส่วนบุคคล): * ให้นักศึกษาเข้าไปที่บัญชี Google (Gmail) หรือ Facebook ของตนเอง
    - ค้นหาเมนูความปลอดภัย (Security) และทำการเปิดใช้งาน การยืนยันแบบ 2 ขั้นตอน (2-Step Verification / 2FA) ให้สำเร็จ
    - ถ่ายภาพหน้าจอ (Capture) ที่แสดงว่าเปิดใช้งาน 2FA สำเร็จแล้ว ส่งให้ครูผู้สอนเพื่อรับคะแนน

7. เอกสารอ้างอิง

1. ศูนย์ประสานการรักษาความมั่นคงปลอดภัยระบบคอมพิวเตอร์ประเทศไทย (ThaiCERT). (2565). คู่มือการป้องกันภัยคุกคามทางไซเบอร์สำหรับองค์กร. สืบค้นจาก https://www.thaicert.or.th

2. Microsoft Security. (2023). What is phishing?. สืบค้นจากเว็บไซต์ Microsoft

3. สำนักงานคณะกรรมการการรักษาความมั่นคงปลอดภัยไซเบอร์แห่งชาติ (สกมช.). (2564). ความรู้เบื้องต้นด้าน Cybersecurity.

8. ภาคผนวก

1. เว็บไซต์ Have I Been Pwned? (https://haveibeenpwned.com)

   วิธีใช้: พิมพ์ที่อยู่อีเมลหรือเบอร์โทรศัพท์ของคุณลงไป

   ประโยชน์: เว็บไซต์จะตรวจสอบฐานข้อมูลทั่วโลกว่า อีเมลของคุณเคยถูกแฮกเกอร์ขโมยรหัสผ่านไปหลุดรั่วไหลอยู่ในตลาดมืด (Dark Web) จากกรณีที่เว็บไซต์บริษัทต่างๆ ถูกแฮกหรือไม่ หากหน้าจอขึ้นสีแดงแสดงว่ารหัสผ่านเก่าของคุณไม่ปลอดภัยแล้ว ให้รีบเปลี่ยนรหัสผ่านทันที!

2. เว็บไซต์ VirusTotal (https://www.virustotal.com)

   วิธีใช้: ก่อนคลิกลิงก์ที่น่าสงสัย หรือก่อนเปิดไฟล์ที่แนบมากับอีเมลแปลกๆ ให้คัดลอกลิงก์นั้น หรืออัปโหลดไฟล์นั้นไปที่เว็บ VirusTotal

   ประโยชน์: ระบบจะนำลิงก์หรือไฟล์นั้นไปสแกนด้วยโปรแกรมแอนตี้ไวรัสชั้นนำระดับโลกกว่า 70 ตัวพร้อมกันภายในไม่กี่วินาที เพื่อยืนยันว่าไฟล์นั้นปลอดภัยและไม่ได้แฝงมัลแวร์เรียกค่าไถ่ (Ransomware) เอาไว้